Hazard Analysis
FitFolio

Team #1, Burn n' Earn
Davis Lenover
Preston Grewal
Angad Chhabra
Farid Bastoros
Zaid Alsaadi

Table 1: Revision History

Date	**Developer(s)**	**Change**
Date1	Name(s)	Description of changes
Date2	Name(s)	Description of changes
...	...	...

Contents

1 Introduction **1**

2 Scope and Purpose of Hazard Analysis **1**

3 System Boundaries and Components **2**

4 Critical Assumptions **2**

5 Failure Mode and Effect Analysis **2**

6 Safety and Security Requirements **2**

6.1 Physical and Psychological Well-being 3
6.2 Activity Data Integrity 6
6.3 Financial Understanding 7
6.4 Market Price and Trade Integrity 8
6.5 Privacy and Permissions 10
6.6 Social Feed 12
6.7 Account Security 13
6.8 Traceability Summary 15

7 Roadmap **16**

8 Appendix — Generative AI Use Disclosure **17**

8.1 AI Tools Used 17
8.2 How and Where Used 17
8.3 Verification of AI-Generated Content 17

9 Appendix — Reflection **18**

[You are free to modify this template. —SS]

1 Introduction

[You can include your definition of what a hazard is here. —SS]

2 Scope and Purpose of Hazard Analysis

FitFolio is designed to change how its users behave: to be more active, to keep up a routine, and to make investing decisions. Features that change behaviour can also cause harm, even when they work as intended. For example, one interview participant described a step streak that now makes them go out walking later than they should (P01). The purpose of this hazard analysis is to identify how FitFolio could cause harm and to define requirements that control it. Hazards are identified using Failure Mode and Effect Analysis (FMEA) in Section 5, and the resulting safety and security requirements are listed in Section 6 and added to the SRS. The aim is to reduce each risk as low as reasonably practicable (ALARP).

In-app currency has no real-world value, so FitFolio cannot cause a direct financial loss. However, given it is expected to simulate real-world trading it can influence a user's financial choices outside the app. Table 2 lists the losses it can cause. Each requirement in Section 6 names the losses it controls.

Table 2: Losses that FitFolio could cause

ID	Loss	Description
L1	Physical harm	Injury or unsafe exercise, such as exercising while sick or injured or late at night, to earn currency or keep a streak.
L2	Psychological harm	Guilt, anxiety or harm to self-image from missed goals, broken streaks or comparison with friends.
L3	Privacy loss	Health, location, portfolio or social data seen by people the user did not choose, or by third parties.
L4	Security loss	Someone else gaining access to a user's account, or currency earned from fabricated activity.
L5	Data loss and integrity	Lost, duplicated or incorrect activity, currency, holdings or trade records.
L6	Financial-understanding harm	A user learning the wrong lessons about investing, or treating simulated results or in-app content as advice for real financial decisions.

The analysis covers the FitFolio mobile app on Android and iOS, its server and database, and its use of the phone's health platform and the market data provider. Hazards are considered both when a part fails and when a feature behaves as intended. The following are out of scope:

- The internal workings of the health platforms and the market data provider. How their failures appear in FitFolio, such as missing activity data or delayed prices, is in scope.
- Injuries that are part of a sport or activity itself.
- Stretch goals (Problem Statement Section 3). They will be analysed if they are built.

3 System Boundaries and Components

[Dividing the system into components will help you brainstorm the hazards. You shouldn't do a full design of the components, just get a feel for the major ones. For projects that involve hardware, the components will typically include each individual piece of hardware. If your software will have a database, or an important library, these are also potential components. —SS]

4 Critical Assumptions

[These assumptions that are made about the software or system. You should minimize the number of assumptions that remove potential hazards. For instance, you could assume a part will never fail, but it is generally better to include this potential failure mode. —SS]

5 Failure Mode and Effect Analysis

[Include your FMEA table here. This is the most important part of this document. —SS] [The safety requirements in the table do not have to have the prefix SR. The most important thing is to show traceability to your SRS. You might trace to requirements you have already written, or you might need to add new requirements. —SS] [If no safety requirement can be devised, other mitigation strategies can be entered in the table, including strategies involving providing additional documentation, and/or test cases. —SS]

6 Safety and Security Requirements

The requirements in this section control the hazards identified in the Failure Mode and Effect Analysis (Section 5). Each requirement states what FitFolio shall do, how a tester decides whether it is met (its fit criterion), why it

is needed, which hazards and losses it controls, and where it appears in the Software Requirements Specification (SRS). Every requirement except SAF-5 appears in the SRS with the same identifier and wording. SAF-5 applies only if goal suggestions are added. Values written as `SMALL_CAPS` constants are defined in SRS Appendix C. Requirements prefixed SAF address physical, psychological and financial-understanding harm. Requirements prefixed SEC address privacy, security and data integrity. Losses L1–L6 are defined in Table 2.

6.1 Physical and Psychological Well-being

SAF-1 (Rest days protect streaks). The system shall let the user mark up to `REST_DAYS_PER_PERIOD` days in each `STREAK_PERIOD` as rest days, and a rest day shall not end the user's activity streak.

- **Fit criterion:** A test user with a streak who marks a day as a rest day and records no activity that day does not have the streak reset to zero at the start of the following day. A request to mark more than `REST_DAYS_PER_PERIOD` rest days in one `STREAK_PERIOD` is refused.
- **Rationale:** Streaks reward consistency, which can lead users to exercise while sick, injured or late at night to keep a streak alive. In user interviews, one participant described a step streak that makes them go out walking when they otherwise would not, including late in the evening (P01), and another admired pushing through exercise regardless of pain (P02).
- **Associated hazards:** FMEA H9, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActRestDay.
- **Roadmap:** Capstone.

SAF-2 (No penalty for a lapse). The system shall not reduce a user's virtual currency balance or simulated holdings when they miss an activity goal or their streak ends, and shall not show a missed goal or an ended streak to other users.

- **Fit criterion:** For a test user who misses their goal on day *d*, the currency balance and simulated holdings at the start of day *d+1* equal those at the end of day *d*. No friend's social feed shows the missed goal or the ended streak.
- **Rationale:** The only consequence of missing a goal is the end of the streak, unless the day is a rest day (SAF-1). Activity recorded on that day still earns currency, as it would with no goal set (SAF-3). Interviews show that keeping a streak going is already a strong motivator (P01). Comparison becomes harmful mainly when a user falls far behind (P02). Taking away earned currency or holdings would also add pressure to exercise when unwell, and would mix

fitness penalties into the investment results the user is trying to learn from.

- **Associated hazards:** FMEA H9, L1 (physical harm), L2 (psychological harm), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.2, FR_ActNoPenalty.
- **Roadmap:** Capstone.

SAF-3 (Goals are optional). The system shall not require the user to set an activity goal in order to earn currency for recorded activity.

- **Fit criterion:** A test user with no activity goal set who records activity receives currency for it.
- **Rationale:** Some users track their activity informally and set no goals (P02). Requiring a goal would push them into targets they did not choose, or shut them out of the reward that is central to FitFolio.
- **Associated hazards:** FMEA H9, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActGoalOptional.
- **Roadmap:** Capstone.

SAF-4 (No automatic goal changes). The system shall not change a user's activity goal without the user's confirmation.

- **Fit criterion:** A test user who exceeds their goal on `GOAL_REVIEW_PERIOD` consecutive days still has the same goal unless they confirm a change.
- **Rationale:** Users fit their goals around their available time and energy. One participant deliberately keeps their step goal fixed, even though they regularly exceed it, because a higher goal takes too much time (P01). Raising goals automatically ignores these limits and leads to overexertion or to goals that are repeatedly missed. Users can still change their own goal at any time (SRS Section 6.2, FR_ActGoal). A change applies from the next day, so lowering a goal cannot keep the current day's streak alive.
- **Associated hazards:** FMEA H9, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.2, FR_ActNoAutoGoal.
- **Roadmap:** Capstone.

SAF-5 (Bounded goal suggestions). The system shall not suggest increasing a user's activity goal by more than `MAX_GOAL_INCREASE` in any one-week period.

- **Fit criterion:** Over any 7-day period, every goal the system suggests to a test user is at most the user's goal at the start of that period multiplied by (1 + `MAX_GOAL_INCREASE`).

- **Rationale:** Large jumps in a goal are not wanted. When raising a challenge, one participant does so only until it is hard but still winnable, and keeps their step goal fixed because a higher target takes too much time (P01). The system therefore limits suggested increases to `MAX_GOAL_INCREASE` per week.
- **Associated hazards:** FMEA H9, L1 (physical harm).
- **In SRS:** None. FitFolio does not suggest goal changes in the capstone.
- **Roadmap:** Future, if goal suggestions are added.

SAF-6 (Reminders only in chosen periods). The system shall send reminders of the types in Table 3 only during the time periods the user has chosen to receive them.

- **Fit criterion:** For a test user who has chosen their reminder periods, no reminder of any type in Table 3 is delivered outside those periods. For a test user who has not chosen any periods, reminders are delivered only during `DEFAULT_REMINDER_PERIOD`.
- **Rationale:** A reminder is only useful when the user can act on it. During times such as working hours, a reminder to be active or to check a portfolio cannot be acted on and only interrupts the user. Late reminders also add pressure to exercise late at night: one participant described their streak making them go out walking at 9 p.m. when they otherwise would not (P01). Letting users choose when they are reminded keeps reminders useful and avoids late-night pressure.
- **Associated hazards:** FMEA H9, L1 (physical harm), L2 (psychological harm).
- **In SRS:** SRS Section 6.6, FR_RemindInPeriods. Implemented in part by SRS Section 6.6, FR_RemindPeriods.
- **Roadmap:** Capstone.

Table 3: Reminder types

Type	Example	Related feature
Activity	Progress toward today's goal, or a streak about to end	Activity goals and streaks (SRS Section 6.2)
Milestone	A goal reached, or a streak or currency milestone	Milestones and activity trends (SRS Section 6.2)
Portfolio	A notable change in simulated portfolio value	Portfolio value (SRS Section 6.3)
Learning	A new concept explanation or knowledge check is available	Learning and feedback (SRS Section 6.4)
Social	A friend shared an update or sent a friend request	Social feed (SRS Section 6.5)

6.2 Activity Data Integrity

SAF-7 (Daily earning cap). The system shall award a user no more than `MAX_DAILY_CURRENCY` virtual currency for recorded activity in any calendar day.

- **Fit criterion:** For a test user whose recorded activity in one calendar day is plausible and would otherwise earn more than `MAX_DAILY_CURRENCY`, the balance increases by exactly `MAX_DAILY_CURRENCY` for that day. Each activity counts toward the calendar day in the user's time zone at the time of the activity.
- **Rationale:** Without a cap, more activity always earns more currency, which rewards exercising past a healthy amount. One participant admired pushing through exercise regardless of pain (P02). A cap also limits what non-exercise motion can earn: phones count steps while riding a bus, and one tracking app was left running for hours after a ride had ended (P01). The cap applies to currency rather than to any one activity, so it works the same way for every supported activity type (Problem Statement Goal 5). The cap limits how much a day can earn, but it does not judge whether an activity record is genuine. SEC-1 covers that.
- **Associated hazards:** FMEA H2, H6, H8, H9, L1 (physical harm), L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 6.2, FR_ActDailyCap.
- **Roadmap:** Capstone.

SEC-1 (Implausible activity earns nothing). The system shall not count an activity record that exceeds the plausibility limits for its activity type toward the user's currency, activity trends, streak or milestones, and shall show the user that the record was not counted.

- **Fit criterion:** A test record of more than `MAX_DAILY_STEPS` steps in one day, or a workout longer than `MAX_WORKOUT_DURATION`, earns no currency, does not appear in the user's activity trends, streak or milestones, and is shown to the user as not counted.
- **Rationale:** SAF-7 limits how much currency a day can earn, but it does not judge whether a record is genuine. Under the cap alone, a fabricated record still earns the full daily amount. An accidental one, such as a tracking app left running for hours after a ride had ended (P01), also distorts the user's activity trends, which the cap does not touch. This requirement rejects records that could not come from real activity. Small amounts of everyday tracking noise, such as steps counted while riding a bus (P01), stay within the limits and are accepted. The limits target records that are clearly impossible.
- **Associated hazards:** FMEA H2, H6, L4 (security loss), L5 (data loss and integrity).
- **In SRS:** SRS Section 6.2, FR_ActPlausible.
- **Roadmap:** Capstone.

6.3 Financial Understanding

SAF-8 (Simulation notice before the first trade). Before the user's first trade, the system shall display a notice stating that the market is simulated, that virtual currency and holdings have no real-world value, and that nothing in FitFolio is financial advice. The system shall not complete the first trade until the user acknowledges the notice.

- **Fit criterion:** A new test user who attempts their first trade is shown the notice and cannot complete the trade until they acknowledge it. The notice contains all three statements: the market is simulated, currency and holdings have no real-world value, and nothing in FitFolio is financial advice.
- **Rationale:** FitFolio teaches investing by letting users practise, and people learn how to act from what they practise: one participant said that formal study did not show them how to act until they had hands-on experience (P02). The lessons a simulation teaches can carry over to real decisions, and a user could mistake simulated results or in-app content for advice on what to do with real money. Users who learn investing on their own also draw on informal sources of mixed quality: one participant learned from online videos and forums, warned that it is easy to end up following the wrong kinds of investing content, and looked for answers tailored to their own situation (P01).
- **Associated hazards:** FMEA H22, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktSimNotice.

- **Roadmap:** Capstone.

SAF-9 (No personalized recommendations). The system shall not recommend that a user buy or sell a specific asset.

- **Fit criterion:** No screen or notification shown to a test user tells them to buy or sell a named asset, or presents assets as a "recommended pick".
- **Rationale:** Recommending specific assets would be personalized financial advice, which FitFolio is not licensed to give, and users may act on it with real money (P01).
- **Associated hazards:** FMEA H22, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktNoRecommend. Implemented in part by SRS Section 6.4, FR_LearnConcentration.
- **Roadmap:** Capstone.

SAF-10 (Label simulated returns). The system shall label every displayed return and portfolio value as simulated.

- **Fit criterion:** Every screen that shows a return or portfolio value shows a "Simulated" label next to it.
- **Rationale:** Simulated returns leave out real costs such as fees and taxes, so users could mistake them for results they would get with real money.
- **Associated hazards:** FMEA H22, L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktLabelReturns.
- **Roadmap:** Capstone.

6.4 Market Price and Trade Integrity

SEC-2 (Price freshness). The system shall display each asset price with the time it was obtained, and shall mark the price as delayed when it is older than `QUOTE_STALENESS_LIMIT`.

- **Fit criterion:** A test price obtained more than `QUOTE_STALENESS_LIMIT` ago is shown with its time and a "Delayed" marker. A price obtained within the limit is shown with its time and no marker.
- **Rationale:** Market data request limits mean prices can lag the real market. A lagging price shown as current misrepresents how the market moved and how a trade performed. The limit matches Problem Statement Goal 4 (prices within 15 minutes of the real market).
- **Associated hazards:** FMEA H12, H45, L5 (data loss and integrity), L6 (financial-understanding harm).

- **In SRS:** SRS Section 6.3, FR_MktPriceAge.
- **Roadmap:** Capstone.

SEC-3 (No trades on stale prices). The system shall not execute a trade while the asset's market is open and the asset's price is older than `QUOTE_STALENESS_LIMIT`.

- **Fit criterion:** While a test asset's market is open and its price is older than `QUOTE_STALENESS_LIMIT`, a trade request for it is refused and the user is told the price is out of date. With a price within the limit, the trade proceeds.
- **Rationale:** A trade at an old price misrepresents how the market moved and teaches the wrong lesson. The limit is the same one SEC-2 uses to mark a price as delayed.
- **Associated hazards:** FMEA H12, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktNoStaleTrade.
- **Roadmap:** Capstone.

SEC-4 (Queue trades while the market is closed). The system shall queue a trade requested while the asset's market is closed, and execute it at the first price obtained after the market next opens.

- **Fit criterion:** A test trade requested while the market is closed is shown to the user as queued, with a notice that it will run at the opening price, and is executed at the first price obtained after the market opens.
- **Rationale:** Many users have time to practise in the evenings and on weekends, when markets are closed. Running those trades at the last closing price would use an old price, and refusing them without explanation would confuse the user.
- **Associated hazards:** FMEA H18, L5 (data loss and integrity), L6 (financial-understanding harm).
- **In SRS:** SRS Section 6.3, FR_MktQueueClosed.
- **Roadmap:** Capstone.

SEC-5 (Complete or reject trades). The system shall record each trade completely, updating both the currency balance and the holdings, or not at all. It shall reject a purchase that costs more than the user's currency balance and a sale of more shares than the user holds.

- **Fit criterion:** A test trade interrupted before it completes leaves the balance and holdings unchanged, and a completed trade changes both. A purchase costing more than the balance, or a sale of more shares than are held, is rejected and changes neither.

- **Rationale:** A partly recorded trade could take currency without adding holdings, or the reverse. Allowing a user to spend more than their balance or sell more than they hold would create currency or holdings that were never earned.
- **Associated hazards:** FMEA H19, H20, H44, L5 (data loss and integrity).
- **In SRS:** SRS Section 6.3, FR_MktAtomicTrade.
- **Roadmap:** Capstone.

SEC-6 (No duplicate trades). The system shall record a trade only once when the same trade request is submitted more than once.

- **Fit criterion:** When a test user submits a trade and the same request is sent again, for example by retrying after a dropped connection, exactly one trade is recorded.
- **Rationale:** Mobile connections drop, and an app or user may resend a trade that already went through. Recording it twice would change the balance and holdings in a way the user did not intend.
- **Associated hazards:** FMEA H16, H44, L5 (data loss and integrity).
- **In SRS:** SRS Section 6.3, FR_MktNoDuplicate.
- **Roadmap:** Capstone.

6.5 Privacy and Permissions

SEC-7 (Least-privilege health access). The system shall request read access only to the health data types listed as activity inputs in the SRS data dictionary, and shall not request permission to write to the health platform.

- **Fit criterion:** Every health permission the system requests is a read permission, and its data type appears in the SRS data dictionary as an activity input.
- **Rationale:** Each extra permission is more personal data that could be exposed. One participant said they look for apps that are frugal with the permissions they ask for (P01).
- **Associated hazards:** FMEA H43, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-7.
- **Roadmap:** Capstone.

SEC-8 (State the purpose of each permission). Before requesting each permission, the system shall tell the user which feature uses that data.

- **Fit criterion:** For every permission request, a test user is shown the feature that uses that data before the request appears.

- **Rationale:** Both participants said they are more willing to grant a permission when it is clear why the app is asking (P01, P02). A user who denies a health permission earns nothing for that activity and may believe the app is broken.
- **Associated hazards:** FMEA H1, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-8. Implemented in part by SRS Section 6.6, FR_SetPermissionList.
- **Roadmap:** Capstone.

SEC-9 (Consent and withdrawal). The system shall obtain the user's consent before it first reads their health data, and shall stop reading health data when the user withdraws consent in the app.

- **Fit criterion:** A new test user's health data is not read until they consent. After they withdraw consent in the app, no further health data is read.
- **Rationale:** Canada's Personal Information Protection and Electronic Documents Act (PIPEDA) requires consent to collect personal information and lets people withdraw it. Health data is among the most sensitive data FitFolio handles.
- **Associated hazards:** L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-9. Implemented in part by SRS Section 6.6, FR_SetWithdrawConsent.
- **Roadmap:** Capstone.

SEC-10 (Data minimization). The system shall send activity data from the user's mobile device to its server only as daily totals for each activity type, not as individual activity records.

- **Fit criterion:** The activity data a test phone sends to the server contains only daily totals for each activity type and no individual activity records.
- **Rationale:** Data that never leaves the phone cannot be exposed by a breach of the server. One participant prefers tools that keep their data on their own device rather than in the cloud (P01).
- **Associated hazards:** FMEA H43, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-10.
- **Roadmap:** Capstone.

SEC-11 (No data to third parties). The system shall not send users' personal or health data to any third party, other than a user's email address and password reset link to the email service that delivers it. Requests to the market data provider shall identify assets only by symbol.

- **Fit criterion:** Every outgoing request from a test mobile device and from the server goes to FitFolio's own server, the market data provider or the email service. Requests to the market data provider contain no personal or health data and identify assets only by symbol. Requests to the email service contain no personal or health data other than the user's email address and their password reset link.
- **Rationale:** Participants judge apps by what happens to their data: one chose apps where their data is not sold (P01), and another wants their data kept secure by a reputable company (P02). Password reset by email (SRS Section 6.1, FR_AcctResetPassword) needs an email service, so it receives only the address and the reset link.
- **Associated hazards:** L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-11.
- **Roadmap:** Capstone.

SEC-12 (No location data). The system shall not read or store location or route data.

- **Fit criterion:** The permissions a test build requests include no location permission, and no location or route data is stored on the phone or the server.
- **Rationale:** None of FitFolio's features need location. Location or route data, such as the route maps some workouts store in the health platform, could reveal where a user lives or regularly goes.
- **Associated hazards:** FMEA H33, L1 (physical harm), L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-12.
- **Roadmap:** Capstone.

6.6 Social Feed

SEC-13 (Private by default). The system shall show a user's statistics only to that user until they choose to share them, and shall show a shared update only to the friends the user selected for it. When the user deletes a shared update or removes a friend, the system shall stop showing the affected shared updates to that friend.

- **Fit criterion:** A test user's new statistic is visible to no other user. Once shared with selected friends, it is visible to exactly those friends. After the user deletes the shared update or removes one of those friends, the shared update no longer appears in that friend's social feed.
- **Rationale:** Problem Statement Goal 3 measures success by users controlling who sees each shared statistic. Friends are expected to see only what a user chooses to share (Problem Statement 1.3).

- **Associated hazards:** FMEA H30, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-13. Implemented in part by SRS Section 6.5, FR_SocialChooseFriends, FR_SocialDeleteUpdate and FR_SocialRemove.
- **Roadmap:** Capstone.

SEC-14 (No location detail in shared updates). The system shall not include location, route or the exact time an activity took place in shared updates.

- **Fit criterion:** No shared update shown to a test user's friends contains a location, a route, or the exact time an activity took place.
- **Rationale:** A route or location, especially combined with when an activity happened, can reveal where a user lives, works or regularly goes. One participant pointed out that removing names does not make a person anonymous, because context can reveal who they are (P01).
- **Associated hazards:** FMEA H31, H33, L1 (physical harm), L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-14.
- **Roadmap:** Capstone.

SAF-11 (No rankings between users). The system shall not rank users against each other by activity, currency or portfolio performance.

- **Fit criterion:** No screen shown to a test user orders users by activity, currency or portfolio performance, or shows a user's position relative to others.
- **Rationale:** Seeing friends' progress can motivate, but comparison becomes harmful when a user is far behind (P02). A ranking makes that gap explicit and places someone last. Leaderboards are a stretch goal (Problem Statement Section 3). If they are built, they should be opt-in.
- **Associated hazards:** FMEA H9, L2 (psychological harm).
- **In SRS:** SRS Section 6.5, FR_SocialNoRanking.
- **Roadmap:** Capstone. Opt-in leaderboards: Future, with the stretch goal.

6.7 Account Security

SEC-15 (Authenticated access only). The system shall require an authenticated session for every request that reads or changes a user's data, and shall return another user's data, other than their username, only when that user has shared it with the requester.

- **Fit criterion:** A test request without a valid session is rejected. A request for another user's data, other than their username, that was not shared with the requester is rejected, and a request for data that was shared succeeds.
- **Rationale:** Health, portfolio and social data must reach only the account it belongs to or the friends it was shared with. SEC-13 sets what a user shares. Usernames are the exception because friend requests are sent by username (SRS Section 6.5, FR_SocialRequest).
- **Associated hazards:** FMEA H39, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-15.
- **Roadmap:** Capstone.

SEC-16 (Protect data in transit and at rest). The system shall encrypt user data in transit between the phone and the server, and when stored on the server, including in backups.

- **Fit criterion:** Inspecting the network traffic between a test phone and the server, the data stored on the server, and its backups shows no readable user data.
- **Rationale:** Data in transit can be intercepted on public networks, and stored data can be exposed if the server or a backup is compromised. Participants want their data kept secure (P02).
- **Associated hazards:** FMEA H40, H43, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-16.
- **Roadmap:** Capstone.

SEC-17 (Session expiry). The system shall end a session when the user signs out of it or when it has not been used for `SESSION_TIMEOUT`, after which the user must sign in again.

- **Fit criterion:** A test session is rejected after the user signs out of it, and after it is left unused for longer than `SESSION_TIMEOUT`. In both cases the user must sign in again to continue.
- **Rationale:** A lost or shared phone, or a stolen session, gives access to a user's health and portfolio data for as long as the session stays valid. Ending unused sessions limits that window, and ending a session at sign-out stops a copied session from being reused (SRS Section 6.1, FR_AcctSignOut).
- **Associated hazards:** FMEA H36, L3 (privacy loss), L4 (security loss).
- **In SRS:** SRS Section 7.3, SEC-17.

- **Roadmap:** Capstone.

SEC-18 (In-app account deletion). The system shall let the user delete their account from within the app, and shall delete their account details, profile, activity totals, currency balance, holdings, trades, learning progress, shared updates, friend list and friend requests from the server and its backups within `DATA_DELETION_PERIOD` of the request.

- **Fit criterion:** After a test user deletes their account in the app, they can no longer sign in. Within `DATA_DELETION_PERIOD`, neither the server nor its backups hold any of their account details, profile, activity totals, currency balance, holdings, trades, learning progress, shared updates, friend list or friend requests, and none of their shared updates appear in friends' social feeds.
- **Rationale:** PIPEDA lets people withdraw consent and limits keeping personal information longer than it is needed. The Apple App Store also requires apps that let users create an account to offer account deletion within the app (App Store Review Guideline 5.1.1(v)).
- **Associated hazards:** FMEA H38, L3 (privacy loss).
- **In SRS:** SRS Section 7.3, SEC-18. Implemented in part by SRS Section 6.1, FR_AcctDelete.
- **Roadmap:** Capstone.

6.8 Traceability Summary

Table 4 summarises each requirement, the hazards it controls, and where it appears in the SRS.

Table 4: Safety and security requirements traceability

ID	FMEA rows	Losses	SRS	Roadmap
SAF-1	H9	L1, L2	FR_ActRestDay	Capstone
SAF-2	H9	L1, L2, L6	FR_ActNoPenalty	Capstone
SAF-3	H9	L1, L2	FR_ActGoalOptional	Capstone
SAF-4	H9	L1, L2	FR_ActNoAutoGoal	Capstone
SAF-5	H9	L1	–	Future
SAF-6	H9	L1, L2	FR_RemindInPeriods	Capstone
SAF-7	H2, H6, H8, H9	L1, L4, L5	FR_ActDailyCap	Capstone
SAF-8	H22	L6	FR_MktSimNotice	Capstone
SAF-9	H22	L6	FR_MktNoRecommend	Capstone
SAF-10	H22	L6	FR_MktLabelReturns	Capstone
SAF-11	H9	L2	FR_SocialNoRanking	Capstone
SEC-1	H2, H6	L4, L5	FR_ActPlausible	Capstone
SEC-2	H12, H45	L5, L6	FR_MktPriceAge	Capstone
SEC-3	H12	L5, L6	FR_MktNoStaleTrade	Capstone
SEC-4	H18	L5, L6	FR_MktQueueClosed	Capstone
SEC-5	H19, H20, H44	L5	FR_MktAtomicTrade	Capstone
SEC-6	H16, H44	L5	FR_MktNoDuplicate	Capstone
SEC-7	H43	L3	Section 7.3	Capstone
SEC-8	H1	L3	Section 7.3	Capstone
SEC-9	–	L3	Section 7.3	Capstone
SEC-10	H43	L3	Section 7.3	Capstone
SEC-11	–	L3	Section 7.3	Capstone
SEC-12	H33	L1, L3	Section 7.3	Capstone
SEC-13	H30	L3	Section 7.3	Capstone
SEC-14	H31, H33	L1, L3	Section 7.3	Capstone
SEC-15	H39	L3, L4	Section 7.3	Capstone
SEC-16	H40, H43	L3, L4	Section 7.3	Capstone
SEC-17	H36	L3, L4	Section 7.3	Capstone
SEC-18	H38	L3	Section 7.3	Capstone

7 Roadmap

[Which safety requirements will be implemented as part of the capstone timeline? Which requirements will be implemented in the future? —SS]

8 Appendix — Generative AI Use Disclosure

[ChatGPT (version 5) was used to brainstorm ideas for the template for this disclose section. —SS]

8.1 AI Tools Used

[Give the name of the AI tool(s) used and the version. —SS]

8.2 How and Where Used

[Explain what the tool(s) were used for. Examples include: brainstorming, explaining a technical concept, reviewing the document, generating or modifying text, generating or modifying diagrams, identifying errors or omissions or inconsistencies. —SS]

[For each of the uses, identify which parts of the document were affected. —SS]

[You do not need to report every interaction, but you should disclose the uses that materially contributed to your work —SS]

8.3 Verification of AI-Generated Content

[

- Describe how the team checked AI-generated or AI-assisted material before including it in the document.
- In particular, verify factual claims, technical assertions, requirements, calculations, references, and other information for which an AI system may produce incorrect or fabricated results.
- **The team is responsible for the accuracy, completeness, consistency, and appropriateness of the submitted document, regardless of whether material was generated by a human or an AI system.**

—SS]

9 Appendix — Reflection

[Not required for CAS 741 —SS]

The purpose of reflection questions is to give you a chance to assess your own learning and that of your group as a whole, and to find ways to improve in the future. Reflection is an important part of the learning process. Reflection is also an essential component of a successful software development process.

Reflections are most interesting and useful when they're honest, even if the stories they tell are imperfect. You will be marked based on your depth of thought and analysis, and not based on the content of the reflections themselves. Thus, for full marks we encourage you to answer openly and honestly and to avoid simply writing "what you think the evaluator wants to hear."

Please answer the following questions. Some questions can be answered on the team level, but where appropriate, each team member should write their own response:

1. What went well while writing this deliverable?
2. What pain points did you experience during this deliverable, and how did you resolve them?
3. Which of your listed risks had your team thought of before this deliverable, and which did you think of while doing this deliverable? For the latter ones (ones you thought of while doing the Hazard Analysis), how did they come about?
4. Other than the risk of physical harm (some projects may not have any appreciable risks of this form), list at least 2 other types of risk in software products. Why are they important to consider?

2. What pain points did you experience during this deliverable, and how did you resolve them?

Davis: The main pain point for me was that the two halves of the analysis were written in parallel and only connected at the end. I wrote the safety and security requirements in Section 6 while Farid wrote the FMEA in Section 5 on his own branch. His FMEA pointed to requirement IDs that did not exist yet, and my requirements had placeholders where their FMEA rows should go, so neither of us could link to the other until we compared our work near the deadline. Design decisions also changed partway through. For example, we first planned to use location data and later dropped it, and I added requirements for trading on out-of-date prices to match Farid's FMEA. Because I inserted these new requirements in the middle of the list, the IDs after them shifted, and references in other members' sections had to be renumbered. We spent the last few days mapping each hazard to its requirements, filling in the traceability table and finding hazards that no requirement covered yet. I resolved this by mapping every requirement to its FMEA rows, completing the traceability table,

and listing the remaining gaps for Farid in my pull request. Next time, I would agree on the ID scheme with the team at the start and only ever add new IDs at the end, and share an early draft of the hazard list and the requirement list so that both sides can link to each other from the beginning.